Lab 03 – Network Segmentation Design – Solutions

Industrial Security (Bachelor) • Maps to Section 03 • 45 min

LAB 03

Goal

Lecturer / TA reference for Lab 03: a worked Purdue layout for a small water utility, a per-conduit rule sketch, the justifications students should arrive at, the common mistakes to mark down, and a grading rubric.

Sample Purdue layout – small water utility

Level	Zone	Sample assets
L0	Field I/O	Chlorine dosing pump, raw-water flow meter (4–20 mA), reservoir level transmitter, motorised valve actuator.
L1	Basic control	Schneider Modicon M580 PLC (intake), Siemens S7-1500 PLC (dosing), redundant RTU at remote tank.
L2	Area supervision	AVEVA / Wonderware InTouch HMI, redundant SCADA pair, engineering workstation (UNITY Pro / TIA).
L3	Site operations	OSIsoft PI historian, MES, AD/RADIUS for OT, NTP/PTP grandmaster (GPS-disciplined), patch-staging server.
L3.5	Industrial DMZ	Reverse proxy for vendor portal, Microsoft RDS jump host (MFA), PI-to-PI replication node, antivirus relay.
L4	Corporate IT	Office AD, file shares, ERP/SAP front-end, business analytics that consume the replicated historian.
L5	Enterprise / cloud	Group reporting, regulator submissions, cloud BI (Azure / AWS), tenant identity provider.

Boundary devices. Industrial firewall (Hirschmann RSP / Fortinet Rugged 60F / Tofino) between L3 and L3.5 with deep packet inspection for Modbus, OPC UA, S7. Hardware data diode (Owl / Waterfall) for L3→L4 historian replication. All cross-level flows terminate in L3.5 – never end-to-end through it.

Conduit rule table – expected rows

Source	Destination	Protocol/Port	Direction	Notes
L2 HMI	L1 PLC	Modbus/TCP 502, S7 102	req/resp	allowlist by IP
L3 PI	L2 SCADA	OPC UA 4840	poll	client cert
L3 NTP	L0/L1/L2	NTP 123	one-way	stratum-1
L3.5 jump	L2 EWS	RDP 3389	inbound	MFA + session record
L3.5 reverse-px	L3.5 jump	HTTPS 443	inbound	vendor SSO
L3 PI	L4 PI-collective	PI-to-PI 5450	*diode*	one-way, L3→L4 only
L4 AD	L3 AD	–	*denied*	separate forest
L1 PLC	L4 anything	–	*denied*	no direct path

Justification points students must articulate

Diode at L3→L4. The historian is the only legitimate egress from OT. A hardware diode enforces *by physics* that no packet can flow back into L3, so a compromised corporate analytics box cannot pivot to PI and from there to SCADA. Stateful firewall rules degrade with misconfiguration; a diode does not.

Jump host in L3.5. Concentrates vendor / engineer remote access at one auditable choke point: MFA, session recording, brokered credentials. Without it every vendor laptop is a VPN endpoint into OT, and revoking access becomes a per-vendor scramble.

No direct L1 ↔ L4. In IT the CIA priority is C > I > A; in OT it is A > I > C (availability and safety first). A direct conduit lets an IT-side incident (ransomware, AD outage, mis-applied patch) propagate to assets whose failure mode is physical. Each Purdue boundary is a deliberate latency/blast-radius break.

NTP/PTP grandmaster in L3. Forensics, IEC 62443 logging, and certificate validity all need a common, trusted clock. Pulling time from L4/L5 couples OT availability to corporate DNS and routing.

Common student mistakes – mark down

- Arrow drawn directly from an L1 PLC (or L2 HMI) to an L4 or L5 service "for reporting" – the conduit must terminate in L3.5.
- HMI placed in L3.5 (it belongs in L2; the iDMZ holds *brokers*, not operator consoles).
- L3.5 drawn as a single firewall rule rather than a real zone with its own hosts, switching, and patch lifecycle.
- Bidirectional arrow on the historian replication conduit – defeats the point of the diode.
- NTP sourced from `pool.ntp.org` on every PLC.
- AD trust extended from corporate into OT (single forest); kerberoasting on the IT side then yields domain admin in the plant.
- Vendor remote access shown as "VPN to PLC" with no jump host, no MFA, no recording.

Grading rubric

All seven Purdue levels labelled, iDMZ explicitly named L3.5	3 pts
At least two concrete assets per level (real product names)	2 pts
Industrial firewall between L3 and L3.5, no rule-free crossings	2 pts
Hardware diode on historian replication, direction L3→L4 only	2 pts
Jump host in L3.5 for vendor / engineer access (MFA noted)	2 pts
Conduit table with source, destination, protocol, port, direction	3 pts
Written justification covers CIA inversion + diode rationale	3 pts
No direct L1↔L4 path; no HMI in DMZ	2 pts
NTP/PTP source inside OT, not pulled from L4/L5	1 pt
Total	**20 pts**

Optional GNS3 build: +2 pts if `nmap -Pn` from Enterprise to an L2 host returns 0 open ports and the pfSense rule set is screenshotted.